

MÉMOIRE DE FIN D'ÉTUDES - ENSPY
AUDIT DE SÉCURITÉ APPLICATIVE
Méthode MUSA - Cas GIDOCEP / SOLTEC

TERMES DE RÉFÉRENCE DE MISSION :

Mission MUSA-GIDOCEP-2026-SOLTEC

Référence mission	MUSA-GIDOCEP-2026-SOLTEC
Type de document	Termes de Référence
Date d'établissement	
Version	V1.0 Finale
Statut	Validé ; mission conduite et rapport d'audit transmis à SOLTEC
Commanditaire	Direction Générale SOLTEC
Chef de mission	TOMI OLAMA Gabrielle Solange, étudiante-Cyber Sécurité et Investigation Numérique, ENSPY
Encadreur professionnel	M. Patrick MBOUL, Ingénieur Informatique, RSSI SOLTEC
Superviseur académique	M. Lauraine TIOGNING, Chargé de cours UY1
Classification	CONFIDENTIEL - Usage exclusif mission de fin d'études

1. Contexte et justification de la mission

SOLTEC est une petite et moyenne entreprise (PME) camerounaise éditrice de GIDOCEP, une application de gestion financière destinée aux établissements publics camerounais. Comme la plupart des PME du secteur, SOLTEC ne peut supporter, sur un même cycle budgétaire, le coût cumulé d'un audit applicatif classique et d'un audit de sécurité distinct deux démarches habituellement conduites séparément dans les grandes organisations.

Le présent mémoire propose et applique MUSA (Méthode Unifiée d'Audit de Sécurité Applicative), une méthode fusionnant en une seule grille d'évaluation les assertions applicatives et les assertions de sécurité, afin de rendre l'audit accessible aux PME dans un seul cycle, sans sacrifier la couverture des deux dimensions.

La présente mission applique MUSA au cas réel de GIDOCEP, dans le cadre du mémoire de fin d'études en Cybersécurité et Investigation Numériques à l'ENSPY, sous l'encadrement académique de M. TIOGNING (ENSPY) et l'encadrement professionnel de M. Patrick MBOUL (SOLTEC).

2. Objectifs de l'audit

2.1 Objectif principal

Fournir une évaluation fusionnée, documentée et reproductible du niveau de maîtrise applicative et sécuritaire de GIDOCEP, en testant la méthode MUSA comme alternative viable aux audits séparés pour les PME camerounaises.

2.2 Objectifs spécifiques (par domaine fusionné MUSA)

Inspirée du cours d'audit des systèmes d'information HN3-ENSPY disponible sur le dépôt github : <https://github.com/Maletyon/INF3226/tree/chapitres> au contexte spécifique MUSA / GIDOCEP / SOLTEC. Document finalisé avec les données réelles de la mission.

- OS-A. Évaluer l'authentification et le contrôle d'accès : robustesse technique (hachage, MFA) et gouvernance (politique, revue périodique des droits, gestion des comptes inactifs).
- OS-B. Évaluer la journalisation et la traçabilité applicative : existence et exploitation effective des logs, détection d'intrusion et procédures de réponse associées.
- OS-C. Évaluer la sécurité des données : chiffrement en transit/repos, contrôle des entrées/sorties, sécurité des interfaces inter-applicatives.
- OS-D. Évaluer la continuité et la sauvegarde applicative : tests de restauration réels, disponibilité, PRA/PCA formalisés.
- OS-E. Évaluer la gouvernance et l'organisation applicative : désignation d'un propriétaire applicatif, politique de patching, protection contre les injections SQL, durcissement des configurations.
- OS-F (méthodologique). Mesurer, pour chaque domaine, l'écart entre réponse technique et réponse organisationnelle au moyen de l'entropie de Shannon, afin d'objectiver les zones de "conformité en trompe-l'œil" (conforme sur un plan mais pas l'autre).

3. Périmètre de la mission

✓ DANS LE PÉRIMÈTRE (IN)	✗ HORS PÉRIMÈTRE (OUT)
• Application GIDOCEP dans son intégralité (modules fonctionnels et sécurité associée) • Contrôles d'authentification et de gestion des accès • Journalisation et traçabilité applicative • Sécurité des données (chiffrement, contrôle des entrées/sorties, interfaces) • Continuité et sauvegarde applicative • Gouvernance et organisation applicative autour de GIDOCEP	• Audit du reste du portefeuille logiciel SOLTEC (hors GIDOCEP) • Test d'intrusion (pentest) approfondi — mission spécialisée distincte • Audit financier et budgétaire de SOLTEC en tant qu'entreprise • Audit des projets de développement futurs non encore engagés • Audit des infrastructures réseau hors périmètre applicatif GIDOCEP

Précision complémentaire sur le périmètre : le référentiel fusionné a été étendu en cours de cadrage de 15 à 21 assertions (ajout des points G1 à G6 couvrant le contrôle de version, la classification, la journalisation des consultations, les droits par document, l'archivage légal et la destruction sécurisée des documents), afin de mieux couvrir le cycle de vie documentaire propre à une application de gestion comptable publique. L'analyse statique du code source (SAST) n'a pas pu être réalisée, SOLTEC n'ayant pas mis le code source à disposition.

4. Architecture du référentiel fusionné MUSA appliqué à GIDOCEP

Le référentiel MUSA appliqué à GIDOCEP comprend 15 assertions fusionnées réparties en 5 domaines (contre des référentiels séparés pouvant dépasser 30-40 assertions dans une approche non fusionnée) :

Domaine	Assertions fusionnées couvertes	Nb assertions	Réf. Outil MUSA
A. Authentification & Contrôle d'accès	Authentification (A1), Gestion des accès applicatifs (A2), Comptes inactifs (A3)	3	A1-A3
B. Journalisation & Traçabilité	Journalisation applicative (B1), Détection d'intrusion (B2), Journalisation des consultations (G3)	3	B1-B2, G3

Inspirée du cours d'audit des systèmes d'information HN3-ENSPY disponible sur le dépôt github : <https://github.com/Maletyon/INF3226/tree/chapitres> au contexte spécifique MUSA / GIDOCEP / SOLTEC. Document finalisé avec les données réelles de la mission.

C. Sécurité des données	Chiffrement (C1), Contrôle des entrées (C2), Contrôle des sorties (C3), Sécurité des interfaces (C4), Contrôle de version des documents (G1), Classification des documents (G2), Gestion des droits par document (G4)	7	C1-C4, G1, G2, G4
D. Continuité & Sauvegarde	Sauvegarde applicative (D1), Disponibilité applicative (D2), Archivage légal (G5)	3	D1-D2, G5
E. Gouvernance & Organisation	Propriétaire applicatif (E1), Politique de sécurité (E2), Protection injections SQL (E3), Configuration sécurisée (E4), Destruction sécurisée (G6)	5	E1-E4, G6
TOTAL	21 assertions fusionnées (contre 15 dans le référentiel initial ,6 assertions complémentaires « G » ajoutées en cours de cadrage)	21	A1-A3, B1-B2, C1-C4, D1-D2, E1-E4, G1-G6

Chaque assertion fusionnée porte une double sous-réponse technique (OK/KO/NSP) et organisationnelle (OK/KO/NSP) dont la combinaison produit la réponse fusionnée finale (O/N/PAS), calculée automatiquement dans l'Outil MUSA.

5. Méthodologie d'audit

5.1 Approche générale

L'audit s'inscrit dans le cadre d'ISO 19011:2018 et combine quatre techniques complémentaires, adaptées au format fusionné :

- Revue documentaire : spécifications techniques GIDOCEP
- Entretiens fusionnés (Guide d'entretien MUSA) : chaque question teste simultanément le volet technique et le volet organisationnel d'une même assertion, avec un seul interlocuteur ou un nombre réduit d'interlocuteurs, cohérent avec la taille d'une PME
- Tests et vérifications techniques : configuration, droits d'accès, chiffrement, tests de restauration de sauvegarde
- Analyse comparative et calcul d'entropie : rapprochement entre réponse technique et réponse organisationnelle par assertion, calcul de l'entropie de Shannon par domaine

6. Risques préliminaires identifiés

Risques préliminaires à affiner lors de la phase de planification, sur la base de la connaissance actuelle de GIDOCEP :

N°	Risque identifié	Domaine MUSA	Criticité	Constat requis
R01	Absence de séparation stricte des rôles applicatifs, risque de cumul de privilèges non contrôlé	A	ÉLEVÉ	CONFIRMÉ ; assertion A2 : Non Conforme (criticité 9/9). Séparation des profils techniquement effective, mais absence de matrice des droits d'accès formalisée.
R02	Journalisation applicative non exploitée en pratique malgré son existence technique	B	ÉLEVÉ	CONFIRMÉ ; assertion B1 : Non Conforme (criticité 9/9). Journal des opérations actif, mais aucune procédure de gestion des incidents formalisée.
R03	Absence de politique formalisée de classification et de chiffrement des documents	C	ÉLEVÉ	CONFIRMÉ ; assertion C1 : Non Conforme (criticité 9/9). Application déployée en HTTP (non HTTPS), cookies non sécurisés, aucune politique de classification/chiffrement.

Inspirée du cours d'audit des systèmes d'information HN3-ENSPY disponible sur le dépôt github : <https://github.com/Maletyon/INF3226/tree/chapitres> au contexte spécifique MUSA / GIDOCEP / SOLTEC. Document finalisé avec les données réelles de la mission.

	financiers gérés par GIDOCEP			
R04	Sauvegardes existantes mais jamais testées en restauration réelle	D	ÉLEVÉ	CONFIRMÉ ; assertion D1 : Non Conforme (criticité 9/9). Sauvegardes effectuées mais jamais testées ; absence de PRA formalisé.
R05	Absence de propriétaire applicatif formellement désigné pour GIDOCEP	E	MOYEN	CONFIRMÉ ; assertion E1 : Non Conforme (criticité 5/9). RSSI identifié informellement (M. Patrick MBOUL) mais sans fiche de poste formalisée.
R06	Écart potentiel entre maturité technique déclarée et maturité organisationnelle réelle justifie la mesure d'entropie MUSA	Transversal	MOYEN	CONFIRMÉ globalement ; écart technique/organisationnel avéré sur 12 des 21 assertions (score de maturité global 29,2 %, Niveau 1 - Initial). La mesure d'entropie MUSA a permis de documenter cet écart de façon reproductible.

7. Calendrier prévisionnel de la mission

Calendrier réellement observé (compressé par rapport au format standard MUSA de 7 à 10 jours de terrain, en raison des contraintes calendaires du mémoire) :

- Phase 0. Préparation : collecte des documents sollicités (cf. Outil LT03) 5 j (avant le 15 Juin 2026)
- Phase 1. Planification : analyse documentaire préliminaire, finalisation du plan d'audit fusionnée avec la Phase 0, close le 15 juin 2026 (réunion de lancement)
- Phase 2. Terrain : entretiens fusionnés par domaine (A à E), tests techniques, 4 j (17 au 20 juin 2026)
- Phase 3. Analyse et rédaction : calcul des réponses fusionnées, entropie, rédaction des constats, 21 juin au 10 juillet 2026 (environ)
- Procédure contradictoire : présentation des constats à SOLTEC, recueil des réponses 10 jours ouverts ; aucune contestation formulée
- Phase 4. Rapport définitif et soutenance du mémoire, rapport transmis ; suivi post-audit planifié sur les jalons J+15 (28/07/2026), M+1 (28/08/2026), M+2 (28/09/2026), M+3 (28/10/2026)

8. Composition de l'équipe de mission

Conformément à la logique MUSA pour PME, la mission est conduite par un auditeur unique cumulant les compétences applicatif et sécurité :

- TOMI OLAMA Gabrielle Solange Chef de mission / étudiante-auditrice- ENSPY, option Cybersécurité et Investigation Numériques
- M. Patrick MBOUL : Encadreur professionnel / Expert métier - SOLTEC
- M. Lauraine TIOGNING : Superviseur académique - ENSPY
- M. NJEI CHECK : Référent institutionnel (Directeur du Département d'Audit de Sécurité de l'ANTIC) : supervision méthodologique et alignement avec le référentiel ANTIC
- M. MINKA MI NGUIDJOI Thierry Emmanuel : Superviseur général (Chief Cybersecurity Officer) validation de la méthodologie MUSA et cohérence scientifique de la démarche

Inspirée du cours d'audit des systèmes d'information HN3-ENSPY disponible sur le dépôt github : <https://github.com/Maletyon/INF3226/tree/chapitres> au contexte spécifique MUSA / GIDOCEP / SOLTEC. Document finalisé avec les données réelles de la mission.

9. Livrables attendus

- Dossier de mission MUSA (TDR, Fiche technique, Guide d'entretien fusionné, Plan d'audit, Outil MUSA)
- Rapport d'audit fusionné GIDOCEP avec grille de conformité par domaine
- Plan de remédiation hiérarchisé
- Mémoire de fin d'études intégrant les résultats comme étude de cas de validation de MUSA

10. Validation du document

Conformément à ISO 19011:2018, le présent document fait l'objet d'une validation formelle par le superviseur académique et l'encadreur professionnel avant tout démarrage des travaux de terrain.

Signataires : TOMI OLAMA Gabrielle Solange (Chef de mission) / M. Lauraine TIOGNING (Superviseur académique) / M. Patrick MBOUL (Encadreur professionnel SOLTEC) document validé, mission conduite.